RAG Governance, Evaluation, and Security Guide

Controls for retrieval quality, grounded generation, access enforcement, monitoring, and adversarial testing

Owner	AI Governance Council	**Version**	1.0
Effective	05 Oct 2026	**Classification**	Internal

1. Governance principles and architecture controls

RAG systems must be evaluated as evidence pipelines, not only as language-model applications.

1.1 Mandatory principles

- Use the simplest architecture that meets measured requirements.
- Separate retrieval evaluation from answer evaluation.
- Enforce identity and document permissions before evidence reaches the model.
- Return citations for factual claims drawn from enterprise content.
- State when evidence is missing or conflicting.

1.2 Required design record

Area	Required decision
Sources	Approved repositories, owners, refresh method
Retrieval	Keyword, vector, hybrid, filters, reranking
Generation	Model, prompt, evidence limits, citation format
Security	Identity, access filters, secrets, tool permissions
Operations	Logging, cost cap, latency target, incident owner

Foundry IQ usage: Record knowledge sources, reasoning effort, identity flow, preview dependencies, and fallback behavior.

2. Evaluation plan

A production candidate must pass a representative gold set before release and after material changes.

2.1 Evaluation dimensions

Dimension	Example measure	What it detects
Retrieval recall	Recall@K	Expected evidence never enters candidate set
Ranking quality	MRR or nDCG	Correct evidence is ranked too low
Groundedness	Claim-to-source check	Answer adds unsupported claims
Citation quality	Citation correctness	Source does not support the statement
Operations	p95 latency and cost	Quality is achieved too slowly or expensively

2.2 Gold-set composition

- Exact identifiers and codes.
- Paraphrased symptom or concept questions.
- Multi-hop and multi-source questions.
- Questions requiring current-version filtering.
- Restricted-content tests.
- Questions with no answer in the corpus.

2.3 Change discipline

Change one major variable at a time, rerun the fixed evaluation set, and retain before-and-after results. Improvements must not hide regressions in access control or no-answer behavior.

Release threshold: No known access-control failure is acceptable. Quality targets may vary by use case, but security gates are mandatory.

3. Security testing and operational response

Retrieved content is untrusted input and must not be allowed to override system or developer instructions.

3.1 Threat scenarios

Threat	Control
Prompt injection in a document	Treat retrieved text as data; isolate instructions; test adversarial files.
Knowledge-base poisoning	Approve sources; monitor unusual updates; retain provenance.
Data leakage	Apply query-time access filters and minimize logged content.
Runaway agent loop	Set step, time, and cost limits.
Unsafe tool use	Use allow-listed tools with least-privilege identities.

3.2 Incident workflow

- Disable affected source or agent path.
- Preserve query, retrieval, citation, and tool-call traces.
- Identify whether failure occurred in ingestion, retrieval, filtering, prompt construction, generation, or tool use.
- Correct the control and rerun the relevant security and quality tests.

3.3 Minimum evidence retained

Retain source IDs, retrieval parameters, access-filter outcome, selected passages, model version, prompt version, citations, latency, and tool calls according to the approved logging policy.

RAG test ideas: Insert an untrusted instruction into a Restricted document and verify that the system ignores it and continues enforcing authorization.